

Model Creation using URL encoding result in tDenial of Service Or Data Model Poisoning in mlflow/mlflow

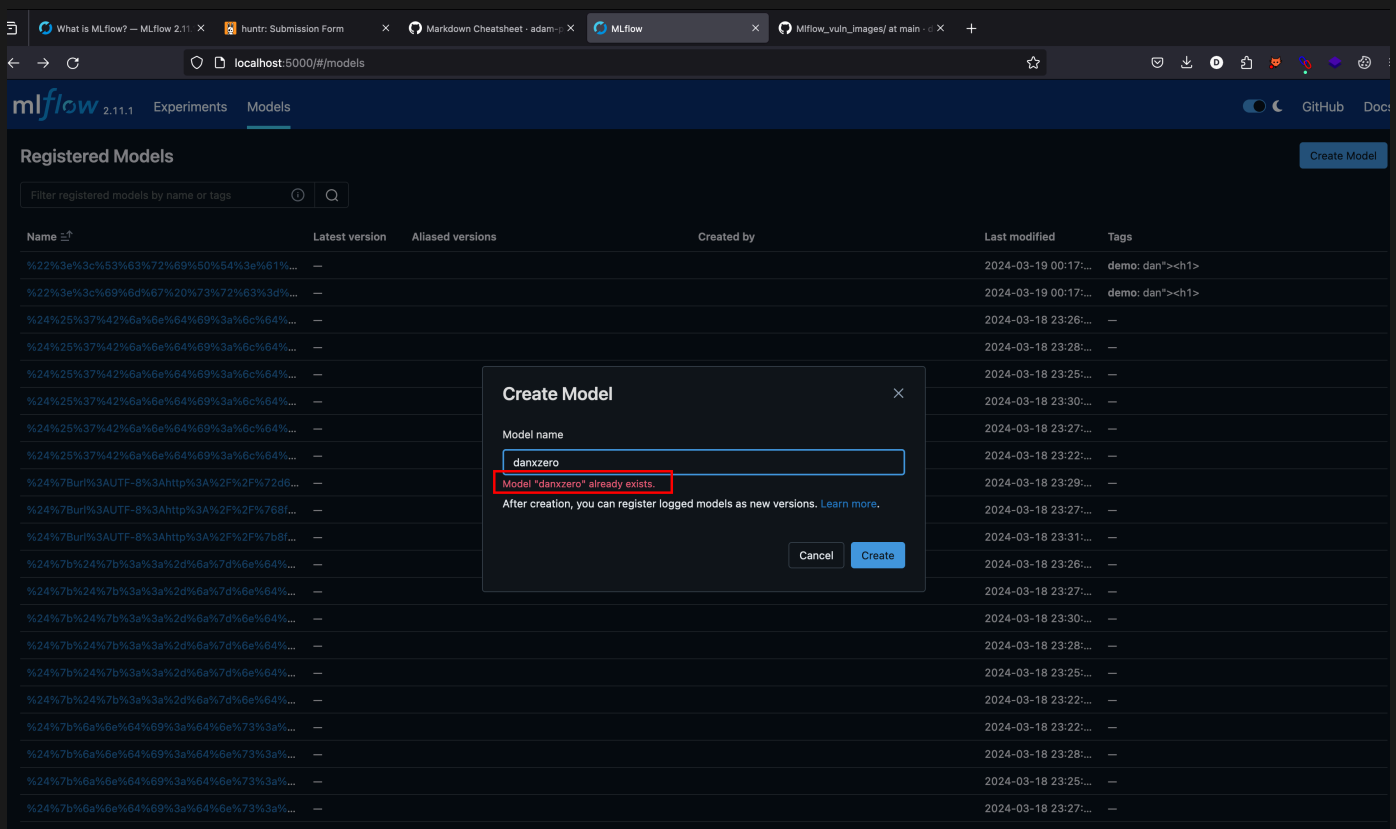
✓ Valid

Reported on Mar 19th 2024

Description

Observation

ML Flow doesn't allow for a user to create a Model with same name.



Issue

Now we can create a same model with same name using URL encoding and if we open or use the new URL encoded valued Modal it will open the previously named modal in rest of process.

What is MLflow? — MLflow 2.11.1 x huntr: Submission Form x Markdown Cheatsheet - adam - x MLflow x dan-xzero/MLflow_vuln_images x

localhost:5000/#/models

mlflow 2.11.1 Experiments Models Create Model

Registered Models

Filter registered models by name or tags

Name	Latest version	Aliased versions	Created by	Last modified	Tags
%22%3e%3c%53%63%72%69%50%54%3e%61%...	—			2024-03-19 00:17:...	demo: dan"><ch1>
%22%3e%3c%69%6d%67%20%73%72%63%3d%...	—			2024-03-19 00:17:...	demo: dan"><ch1>
%24%25%37%42%6a%6e%64%69%3a%6c%64%...	—			2024-03-18 23:26:...	—
%24%25%37%42%6a%6e%64%69%3a%6c%64%...	—			2024-03-18 23:28:...	—
%24%25%37%42%6a%6e%64%69%3a%6c%64%...	—			2024-03-18 23:25:...	—
%24%25%37%42%6a%6e%64%69%3a%6c%64%...	—			2024-03-18 23:30:...	—
%24%25%37%42%6a%6e%64%69%3a%6c%64%...	—			2024-03-18 23:27:...	—
%24%25%37%42%6a%6e%64%69%3a%6c%64%...	—			2024-03-18 23:22:...	—
%24%7burl%3AUTf-8%3Ahttp%3A%2F%2F%72d6...	—			2024-03-18 23:29:...	—
%24%7burl%3AUTf-8%3Ahttp%3A%2F%2F%768f...	—			2024-03-18 23:27:...	—
%24%7burl%3AUTf-8%3Ahttp%3A%2F%2F%7b8f...	—			2024-03-18 23:31:...	—
%24%7b%24%7b%3a%3a%2d%6a%7d%6e%64%...	—			2024-03-18 23:26:...	—
%24%7b%24%7b%3a%3a%2d%6a%7d%6e%64%...	—			2024-03-18 23:27:...	—
%24%7b%24%7b%3a%3a%2d%6a%7d%6e%64%...	—			2024-03-18 23:30:...	—
%24%7b%24%7b%3a%3a%2d%6a%7d%6e%64%...	—			2024-03-18 23:28:...	—
%24%7b%24%7b%3a%3a%2d%6a%7d%6e%64%...	—			2024-03-18 23:25:...	—
%24%7b%24%7b%3a%3a%2d%6a%7d%6e%64%...	—			2024-03-18 23:22:...	—
%24%7b%6a%6e%64%69%3a%64%6e%73%3a%...	—			2024-03-18 23:22:...	—
%24%7b%6a%6e%64%69%3a%64%6e%73%3a%...	—			2024-03-18 23:28:...	—
%24%7b%6a%6e%64%69%3a%64%6e%73%3a%...	—			2024-03-18 23:25:...	—
%24%7b%6a%6e%64%69%3a%64%6e%73%3a%...	—			2024-03-18 23:27:...	—

Create Model

Model name

After creation, you can register logged models as new versions. [Learn more.](#)

Cancel Create

Now Open the newly created Model and it is observed that old model is open.

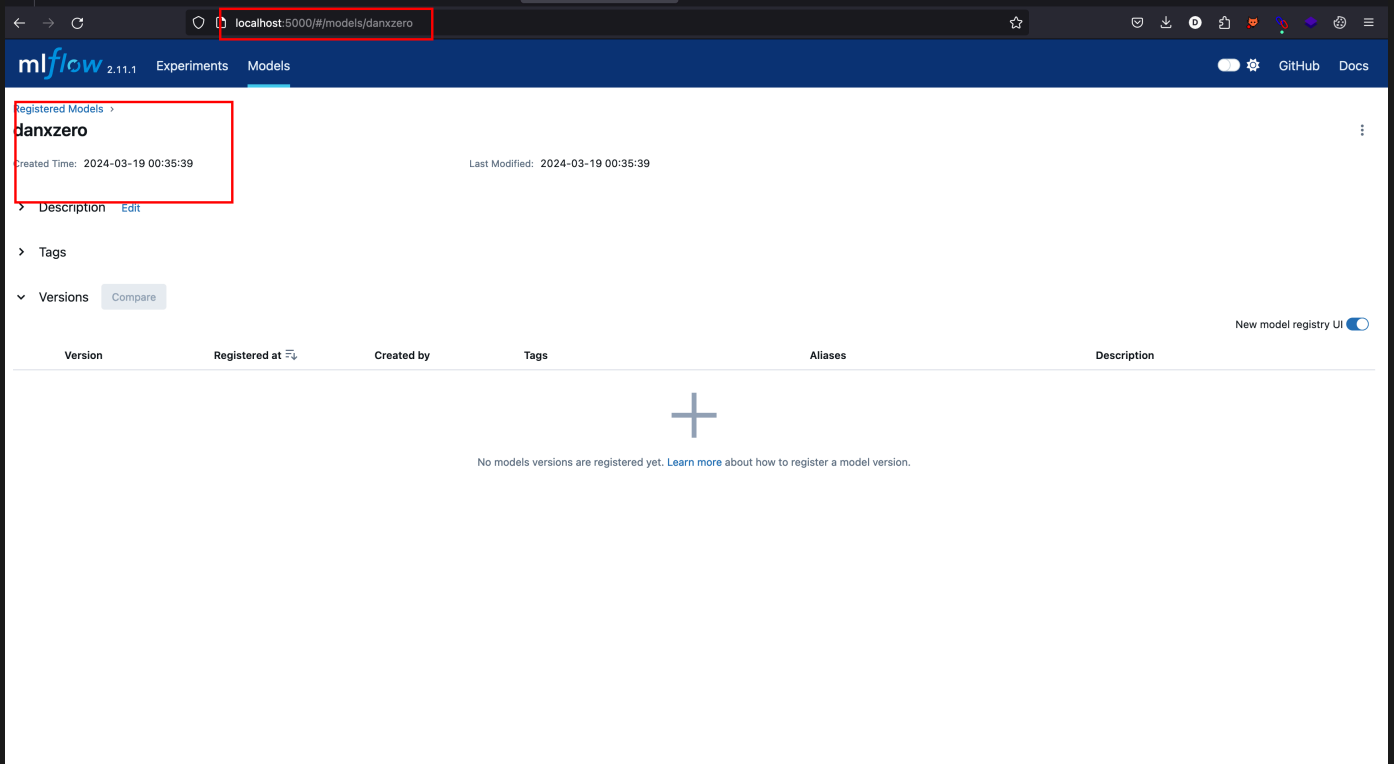
localhost:5000/#/models?page=15

mlflow 2.11.1 Experiments Models Create Model

Registered Models

Filter registered models by name or tags

Name	Latest version	Aliased versions	Created by	Last modified	Tags
dan"><ch1>danish@{7948*2}1337	—			2024-03-18 23:30:...	—
dan"><ch1>danish@{7948+7948}1337	—			2024-03-18 23:30:...	—
dan"><ch1>danish`	—			2024-03-18 23:31:...	—
dan"><ch1>danishor 1=1	—			2024-03-18 23:31:...	—
dan"><ch1>danishor 1=1%23	—			2024-03-18 23:31:...	—
dan"><ch1>danishor 1=1--	—			2024-03-18 23:31:...	—
dan"><ch1>danishor true--	—			2024-03-18 23:31:...	—
dan"><ch1>danishor'!='	—			2024-03-18 23:31:...	—
dan"><ch1>danish{({7948+7948})}1337	—			2024-03-18 23:30:...	—
dan"><ch1>danish{({7949*2})}1337	—			2024-03-18 23:30:...	—
dan"><ch1>danish{name=your@email.com	—			2024-03-18 23:28:...	—
dan*danxzero	—			2024-03-18 23:27:...	—
dan&	—			2024-03-18 23:27:...	—
danxzer%6f	—			2024-03-19 00:35:...	—
danxzer%6f	—			2024-03-19 00:58:...	—
danxzero	—			2024-03-19 00:35:...	—
demo1	—			2024-03-18 22:24:...	—
demo1 inslookup 7ac3a600264a40847-4gl9711nc...	—			2024-03-18 23:23:...	—
demo1 lver	—			2024-03-18 23:23:...	—
demo1 \${curl}\${IFS}70e96d56c8aa8468b7-7bjikkco...	—			2024-03-18 23:26:...	—
demo1 \${ping}-c 2 7e4d54163b9d048da7-4afgkhj9...	—			2024-03-18 23:26:...	—



Impact

Denial of Service An authenticate user might not be able to use the model as it will open different model every time. An Attacker can create an same model with model poisoning and host the model and an authentic user will become victim of that model.

Occurrences

 [README.rst?plain=1 L2](#)

This is link for Readme file The vulnerability lies in validations

 We are processing your report and will contact the **mlflow** team within 24 hours. 2 years ago

 A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists 2 years ago



 **huntr-helper** modified the Severity from High (7.6) to Medium (5.4) 2 years ago



Dan_xzero commented 2 years ago

Researcher

Hi as per my knowledge i think the integrity and availability should be high, Cause. by creating another model with name url encoding you deny the availability of the created model as it will be going to redirect to url decoded value as well thus defeating the purpose of newly created model. and as for integrity once an authentic user try to use his model,

this newly created model which has been trained on poisoned data will serve the authentic user thus integrity should also be high. let me have your thought on this.



Ben Wilson commented 2 years ago

Maintainer

Hi Dan_xzero, this definitely looks like a bug in general, as it is not intended behavior. Thank you for the review of it and we'll be looking to get this fixed for the next minor release.

flow



A **mlflow/mlflow** maintainer has acknowledged this report 2 years ago



Dan_xzero commented 2 years ago

Researcher

Hi Ben, Thanks for reviewing, Kindly share your insight on severity as mentioned above it does impact both integrity and availability highly. Thanks once again for acknowledging the report



Ben Wilson commented 2 years ago

Maintainer

The security implications are pretty low as these servers are not intended to be exposed to the internet. However, the functionality aspect of this is fairly severe from a bug perspective. I would agree with the "Medium" level of this as indicated on the report.

✉ We have contacted a member of the **mlflow** team and are waiting to hear back 2 years ago



Dan_xzero commented 2 years ago

Researcher

Hi Ben, Thankyou for you response, I saw new release, Just wanted to confirm whether this has been also implemented



Dan_xzero commented 2 years ago

Researcher

Any update?



Dan_xzero commented 2 years ago

Researcher

Hi Team, any update. saw another release with commit for the issue, and is this report also be eligible for cve ?



Ben Wilson commented 2 years ago

Maintainer

We can acknowledge this for CVE :) (I can't, but an admin of this site can) It's been patched in MLflow 2.11.3. Thanks again for the report Dan!



Dan_xzero commented 2 years ago

Researcher

Thanks @admin kindly issue the cve for this report



Dan_xzero commented 2 years ago

Researcher

And when can I expect the bounty for this.



Dan_xzero commented 2 years ago

Researcher

Hi, is there any update.



Dan_xzero commented 2 years ago

Researcher

Hi Team, any update.

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1

✓ Marcello validated this vulnerability 2 years ago

\$ dan-xzero has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

👤 CVE-2024-3099 assigned to this report. 2 years ago



Dan_xzero commented 2 years ago

Researcher

Hi can we close the report as it has been fixed as discussed earlier.

⚠ We have sent a warning to the **mlflow** team to inform them that this report will be published in 48 hours 2 years ago

📡 This vulnerability has now been published 2 years ago

👤 CVE-2024-3099 has now been published 2 years ago

✉ We have notified the **mlflow/mlflow** maintainers about this report in their weekly follow-up a year ago

CVE
CVE-2024-3099
Published

Vulnerability Type
CWE-475: Undefined Behavior for Input to API

Severity

Medium (5.4)

Attack vector	Network
Attack complexity	Low
Privileges required	Low
User interaction	None
Scope	Unchanged
Confidentiality	None
Integrity	Low
Availability	Low

[Open in visual CVSS calculator](#)

Registry
Other

Affected Version
2.11.1

Visibility
Public

Status
Awaiting fix

Disclosure Bounty
\$125

Fix Bounty
\$31.25

Found by



Dan_xzero

@dan-xzero

LIGHTWEIGHT



